

1. What is the first step in risk management?

- A. Risk response
- B. Risk identification
- C. Risk assessment
- D. Risk monitoring

Answer: B. Risk identification

Explanation: The risk management process begins with identifying risks to an organization's assets. Only after risks are identified can they be assessed and managed.

2. Which of the following best describes risk appetite?

- A. The amount of risk the organization is willing to accept
- B. The amount of risk the organization is able to mitigate
- C. The minimum level of risk that can be avoided
- D. The organization's ability to respond to risks

Answer: A. The amount of risk the organization is willing to accept

Explanation: Risk appetite defines the level of risk an organization is prepared to tolerate in pursuit of its objectives.

3. In a risk assessment, what does "impact" refer to?

- A. The probability of a threat materializing
- B. The consequences of a risk event
- C. The likelihood of a risk being exploited
- D. The effectiveness of controls

Answer: B. The consequences of a risk event

Explanation: Impact refers to the potential consequences or damage that could occur if a risk materializes.

4. Which of the following is the best method for prioritizing risks?

- A. Qualitative risk assessment
- B. Quantitative risk assessment
- C. Risk ranking based on severity and likelihood
- D. Risk response planning

Answer: C. Risk ranking based on severity and likelihood

Explanation: Prioritizing risks typically involves ranking them based on their potential impact (severity) and the likelihood of occurrence.

5. What is the primary purpose of risk mitigation?

- A. To avoid all risks
- B. To reduce the likelihood and/or impact of a risk
- C. To transfer the risk to a third party
- D. To accept risk without action

Answer: B. To reduce the likelihood and/or impact of a risk

Explanation: Risk mitigation strategies aim to reduce either the likelihood of a risk event occurring or its potential impact.

6. Which of the following is an example of a risk transfer strategy?

- A. Implementing new controls
- B. Purchasing insurance
- C. Accepting the risk
- D. Reducing the risk

Answer: B. Purchasing insurance

Explanation: Risk transfer involves shifting the financial consequences of a risk to another party, often through insurance.

7. Which risk management framework is often used in IT?

- A. COBIT
- B. ITIL
- C. ISO 27001
- D. NIST Risk Management Framework (RMF)

Answer: D. NIST Risk Management Framework (RMF)

Explanation: The NIST Risk Management Framework (RMF) is widely used for managing risk in IT environments, particularly in the US federal sector.

8. Residual risk is best defined as which of the following?

- A. Risk that cannot be mitigated
- B. Risk that remains after implementing controls
- C. Risks that have been completely eliminated
- D. Risks that have been transferred to a third party

Answer: B. Risk that remains after implementing controls

Explanation: Residual risk is the remaining risk after controls have been implemented to reduce the initial (inherent) risk.

9. Which of the following describes a control that reduces the impact of a risk but not the likelihood?

- A. Preventive control
- B. Detective control
- C. Corrective control
- D. Contingency control

Answer: D. Contingency control

Explanation: Contingency controls focus on reducing the impact of a risk event if it occurs but do not affect the likelihood of its occurrence.

10. What is the primary goal of a risk assessment?

- A. To eliminate risks
- B. To reduce risk appetite
- C. To identify and prioritize risks
- D. To ensure compliance with regulations

Answer: C. To identify and prioritize risks

Explanation: Risk assessments aim to identify risks and prioritize them based on their potential impact and likelihood of occurrence.

11. Which of the following is an inherent risk?

- A. Risk that exists after controls
- B. Risk that occurs only under rare conditions
- C. Risk that exists before any controls are implemented
- D. Risk that cannot be avoided

Answer: C. Risk that exists before any controls are implemented

Explanation: Inherent risk is the level of risk before any mitigation or controls are applied.

12. Which term describes the process of ensuring that risk management strategies are aligned with business objectives?

- A. Risk analysis
- B. Risk governance
- C. Risk adjustment
- D. Risk management alignment

Answer: B. Risk governance

Explanation: Risk governance ensures that the risk management approach is aligned with the organization's objectives and governance practices.

13. Which of the following is a key component of risk monitoring?

- A. Implementing risk response strategies
- B. Reviewing risk policies annually
- C. Tracking and reviewing risks on an ongoing basis
- D. Re-evaluating risk appetite

Answer: C. Tracking and reviewing risks on an ongoing basis

Explanation: Risk monitoring involves continuous tracking of risks and controls to ensure they are being managed effectively.

14. Which of the following is a qualitative risk analysis technique?

- A. Monte Carlo simulation
- B. Sensitivity analysis
- C. Probability-impact matrix
- D. Expected monetary value analysis

Answer: C. Probability-impact matrix

Explanation: The probability-impact matrix is a qualitative technique used to rank risks based on their probability of occurrence and impact.

15. What is the purpose of a risk tolerance level?

- A. To eliminate all risk
- B. To define acceptable levels of risk
- C. To minimize financial losses
- D. To identify high-impact risks

Answer: B. To define acceptable levels of risk

Explanation: Risk tolerance is the level of risk that an organization is willing to accept as it pursues its objectives.

16. Which of the following best describes a preventive control?

- A. It reduces the damage caused by a risk event
- B. It detects a risk event when it occurs
- C. It reduces the likelihood of a risk event
- D. It provides a response after a risk event occurs

Answer: C. It reduces the likelihood of a risk event

Explanation: Preventive controls are designed to reduce the likelihood of a risk event occurring.

17. Which of the following is an example of a corrective control?

- A. Backup and recovery systems
- B. Firewalls
- C. Intrusion detection systems
- D. Security policies

Answer: A. Backup and recovery systems

Explanation: Corrective controls are designed to restore systems or data after a risk event has occurred, such as through backup and recovery systems.

18. Risk communication is essential to which part of the risk management process?

- A. Risk identification
- B. Risk assessment
- C. Risk monitoring
- D. All stages

Answer: D. All stages

Explanation: Risk communication is essential throughout the risk management process, as stakeholders must be informed at every stage to ensure effective risk management.

19. Which of the following best describes risk acceptance?

- A. Taking steps to prevent a risk from occurring
- B. Choosing to ignore a risk because of low impact
- C. Formally deciding to accept the consequences of a risk
- D. Implementing controls to manage risk

Answer: C. Formally deciding to accept the consequences of a risk

Explanation: Risk acceptance is when an organization makes a formal decision to accept the potential consequences of a risk without additional action.

20. Which role is primarily responsible for managing and overseeing the risk management process in an organization?

- A. Risk analyst
- B. Risk owner
- C. IT auditor
- D. Chief Information Security Officer (CISO)

Answer: D. Chief Information Security Officer (CISO)

Explanation: The CISO typically oversees the organization's information security risk management process, ensuring that risks are managed in alignment with the organization's goals.